

Vereinbarung zur Auftragsverarbeitung (AVV)

nach Art. 28 DSGVO

zwischen

dem im Registrierungs- bzw. Buchungsprozess angegebenen Unternehmen / Betrieb

– nachfolgend „**Auftraggeber**“ genannt –

und

CareTip UG (haftungsbeschränkt)

Kolonnenstraße 8, 10827 Berlin, Deutschland

– nachfolgend „**Auftragnehmer**“ genannt –

gemeinsam nachfolgend die „**Parteien**“ genannt.

Präambel

Diese Vereinbarung regelt die datenschutzrechtlichen Pflichten der Parteien im Rahmen der Nutzung der CareTip-Plattform. Die Vereinbarung kommt gemäß Art. 28 Abs. 9 DSGVO in elektronischer Form (Textform) durch die Bestätigung des Auftraggebers im Rahmen des Online-Registrierungs- oder Buchungsprozesses zustande.

1. Einleitung, Geltungsbereich, Definitionen

1.1. Dieser Vertrag regelt die Rechte und Pflichten der Parteien im Rahmen einer Verarbeitung von personenbezogenen Daten im Auftrag im Sinne des Art. 28 der EU-Datenschutzgrundverordnung (DSGVO).

1.2. Dieser Vertrag findet Anwendung auf alle Tätigkeiten im Rahmen des Hauptvertrags (Nutzungsvereinbarung / AGB zur CareTip-Plattform), bei denen der Auftragnehmer, seine Mitarbeiter oder durch ihn beauftragte Subunternehmer personenbezogene Daten des Auftraggebers verarbeiten.

1.3. In diesem Vertrag verwendete Begriffe entsprechen ihrer Definition in der DSGVO. Textform (z. B. E-Mail, Checkbox-Bestätigung) ist für Erklärungen ausreichend, sofern nichts anderes vereinbart ist.

2. Gegenstand und Dauer der Verarbeitung

2.1. Der Auftragnehmer übernimmt die Bereitstellung der CareTip-Softwareplattform zur digitalen Abwicklung, Zuordnung und Auswertung von Trinkgeldern und Gästefeedback.

2.2. Gegenstand, Art und Zweck der Verarbeitung sowie die Kategorien von Daten und Betroffenen ergeben sich aus dieser Vereinbarung sowie dem zugrundeliegenden Hauptvertrag.

2.3. Die Verarbeitung beginnt mit der Erstellung des Kundenkontos und erfolgt auf unbestimmte Zeit bis zur Beendigung des Hauptvertrags.

3. Art, Zweck und Umfang der Datenverarbeitung

3.1. Zweck der Verarbeitung:

Erfassung, Verwaltung, Zuordnung, Auswertung und Bereitstellung von digitalen Trinkgeldern, In-App-Benachrichtigungen, Auszahlungs-Umsätzen und Gästefeedback für den Betrieb des Auftraggebers.

3.2. Kategorien personenbezogener Daten:

- **Stammdaten & Kontaktdaten:** Name, E-Mail-Adresse, Telefonnummer,
- **Mitarbeiterdaten:** Profildaten, Identifikations-IDs, Abrechnungs- und Auszahlungsinformationen.
- **Gastdaten (flüchtig/optional):** Freiwillig abgegebenes Feedback, Bewertungsnoten, Transaktions-Metadaten.
- **Technische Daten:** IP-Adressen (anonymisiert/gekürzt), Session-Logs, QR-Scan-Metadaten.

(Hinweis: Besondere Kategorien personenbezogener Daten nach Art. 9 DSGVO, wie z. B. Gesundheitsdaten, werden ausdrücklich nicht verarbeitet).

3.3. Kategorien der Betroffenen:

- Mitarbeiter und Beschäftigte des Auftraggebers
- Kunden / Gäste des Auftraggebers (bei der Nutzung der Trinkgeldfunktion)

4. Pflichten des Auftragnehmers

4.1. Der Auftragnehmer verarbeitet personenbezogene Daten ausschließlich wie vertraglich vereinbart oder auf dokumentierte Weisung des Auftraggebers, es sei denn, er ist durch Unionsrecht oder das Recht der Mitgliedstaaten zur Verarbeitung verpflichtet.

4.2. Der Auftragnehmer sichert zu, dass die zur Verarbeitung befugten Personen zur Vertraulichkeit verpflichtet wurden oder einer angemessenen gesetzlichen Verschwiegenheitspflicht unterliegen.

4.3. Der Auftragnehmer unterstützt den Auftraggeber unter Berücksichtigung der Art der Verarbeitung und der ihm zur Verfügung stehenden Informationen bei der Einhaltung der in den Artikeln 32 bis 36 DSGVO genannten Pflichten (Sicherheitsmaßnahmen, Meldungen von Datenpannen, Datenschutz-Folgenabschätzungen).

4.4. Die Verarbeitungen erfolgen grundsätzlich innerhalb der EU / des EWR. Eine Verarbeitung in Drittländern erfolgt nur bei Vorliegen der gesetzlichen Voraussetzungen der Art. 44 ff. DSGVO (z. B. auf Basis von Angemessenheitsbeschlüssen der EU-Kommission oder EU-Standardvertragsklauseln).

5. Technische und organisatorische Maßnahmen (TOMs)

5.1. Der Auftragnehmer richtet die in **Anlage 1** beschriebenen technischen und organisatorischen Maßnahmen ein und hält diese aufrecht.

5.2. Die Maßnahmen können der technischen Weiterentwicklung angepasst werden, solange das vereinbarte Sicherheitsniveau nicht unterschritten wird.

5.3. Mobiles Arbeiten / Homeoffice ist den Mitarbeitern des Auftragnehmers gestattet, sofern angemessene Sicherheitsvorkehrungen (z. B. verschlüsselte Verbindungen, Passwortschutz, aktuelle Betriebssysteme) eingehalten werden.

6. Unterauftragsverhältnisse (Subunternehmer)

6.1. Der Auftraggeber erteilt dem Auftragnehmer die allgemeine Genehmigung, Subunternehmer hinzuzuziehen. Die bei Vertragsschluss eingesetzten Subunternehmer sind in **Anlage 2** aufgeführt.

6.2. Der Auftragnehmer informiert den Auftraggeber im Voraus über jede beabsichtigte Änderung bezüglich der Hinzuziehung oder Ersetzung von Subunternehmern (z. B. per E-Mail oder In-App-Mitteilung). Der Auftraggeber kann innerhalb von 14 Tagen aus wichtigen datenschutzrechtlichen Gründen Widerspruch einlegen. Erfolgt kein Widerspruch, gilt die Änderung als genehmigt.

6.3. Geht der Subunternehmer Verarbeitungspflichten in einem Drittland ein, stellt der Auftragnehmer das Vorliegen angemessener Datenschutzgarantien (z. B. EU-US Data Privacy Framework) sicher.

7. Rechte des Auftraggebers und Kontrollrechte

7.1. Der Auftragnehmer stellt dem Auftraggeber auf Anfrage alle erforderlichen Informationen zum Nachweis der Einhaltung der Pflichten nach Art. 28 DSGVO zur Verfügung.

7.2. Der Nachweis der Einhaltung kann vorrangig durch die Vorlage aktueller Zertifikate, Berichte unabhängiger Instanzen oder Selbstauskünfte erbracht werden.

7.3. Vor-Ort-Kontrollen beim Auftragnehmer finden nach angemessener Vorankündigung (mindestens 14 Tage) zu gewöhnlichen Geschäftszeiten ohne Störung des Betriebsablaufs statt. Entstehen dem Auftragnehmer durch Vor-Ort-Audits erhebliche Aufwände, können diese dem Auftraggeber nach vorheriger Absprache zu angemessenen Stundensätzen berechnet werden, es sei denn, das Audit ist durch einen begründeten Verdacht eines Datenverstoßes veranlasst.

8. Mitteilungspflichten bei Datenpannen

8.1. Der Auftragnehmer teilt dem Auftraggeber Verletzungen des Schutzes personenbezogener Daten **unverzüglich** mit, nachdem er davon Kenntnis erlangt hat.

8.2. Die Mitteilung enthält die gesetzlich geforderten Mindestangaben zur Art der Verletzung, den betroffenen Kategorien sowie den ergriffenen Schutzmaßnahmen.

9. Beendigung des Auftrags und Datenlöschung

9.1. Nach Beendigung des Hauptvertrags wird der Auftragnehmer alle im Auftrag verarbeiteten Daten nach Wahl des Auftraggebers entweder löschen oder zurückgeben, sofern keine gesetzlichen Aufbewahrungspflichten (z. B. § 147 AO / § 257 HGB für steuerrelevante Transaktionsdaten) einer Löschung entgegenstehen.

9.2. Nach Ablauf von Kontrollöschungs- oder Aufbewahrungsfristen werden die Daten automatisiert gelöscht oder dauerhaft anonymisiert.

10. Haftung

Die Haftung richtet sich nach den Regelungen des Hauptvertrags sowie den gesetzlichen Bestimmungen der DSGVO (insbesondere Art. 82 DSGVO).

Anlage 1 – Technische und organisatorische Maßnahmen (TOMs)

Der Auftragnehmer gewährleistet ein angemessenes Schutzniveau nach Art. 32 DSGVO durch folgende Maßnahmen:

1. Vertraulichkeit (Art. 32 Abs. 1 lit. b DSGVO)

- **Zutrittskontrolle:** Zutritt zu Geschäftsräumen nur für berechtigte Personen; Verschließen von Räumen bei Abwesenheit; Alarmsicherungen.
- **Zugangskontrolle (Systeme):** Authentifizierung über individuelle Benutzerkonten; Nutzung von Zwei-Faktor-Authentifizierung (2FA) bei kritischen Systemen; Durchsetzung komplexer Passwort-Richtlinien.
- **Zugriffskontrolle (Daten):** Rollen- und Rechtekonzept auf Need-to-know-Basis; Mandantentrennung auf Datenbankebene (Isolation von Kundendaten).
- **Trennungsgebot:** Logische Trennung von Test-, Staging- und Produktionsumgebungen; Mandantenspezifische Datenverarbeitung.

2. Integrität (Art. 32 Abs. 1 lit. b DSGVO)

- **Weitergabekontrolle:** Verschlüsselung aller Datenübertragungen nach aktuellem Stand der Technik (TLS 1.2 / TLS 1.3 mit SSL-Zertifikaten); Verschlüsselung ruhender Daten (*Encryption at Rest*) bei Datenbank- und Cloud-Anbietern.
- **Eingabekontrolle:** Protokollierung von Systemzugriffen und administrativen Änderungen (Audit-Logs); Nachvollziehbarkeit von Datenänderungen.

3. Verfügbarkeit und Belastbarkeit (Art. 32 Abs. 1 lit. b DSGVO)

- **Verfügbarkeitskontrolle:** Nutzung hochverfügbarer Cloud-Infrastruktur mit redundanten Serverarchitekturen; Automatisierte tägliche Daten-Backups.
- **Wiederherstellbarkeit:** Reguläre Testläufe zur Einspielung von Backups (Disaster Recovery).

4. Verfahren zur regelmäßigen Überprüfung (Art. 32 Abs. 1 lit. d DSGVO)

- **Datenschutz-Management:** Regelmäßige Mitarbeiterschulungen und Verpflichtung aller Beschäftigten auf das Datengeheimnis; Kontinuierliche Überprüfung und Aktualisierung der Sicherheitsmaßnahmen.

Anlage 2 – Eingesetzte Subunternehmer

Der Auftraggeber genehmigt zum Zeitpunkt des Vertragsschlusses den Einsatz folgender Subunternehmer:

Subunternehmer / Dienstleister	Sitz	Gegenstand der Verarbeitung	Rechtsgrundlage / Drittland-Transfer
Stripe Payments Europe Ltd.	Irland / USA	Zahlungsabwicklung & Auszahlungen	EU-US Data Privacy Framework / EU-Standardvertragsklauseln (SCCs) / DPA
Render Services, Inc.	USA	Anwendungs-Hosting & API-Server	EU-US Data Privacy Framework / EU-Standardvertragsklauseln (SCCs) / DPA
Netlify, Inc.	USA	Frontend-Hosting & Web-Bereitstellung	EU-US Data Privacy Framework / EU-Standardvertragsklauseln (SCCs) / DPA
Plus Five Five, Inc. (Resend)	USA	Versand von System-E-Mails	EU-US Data Privacy Framework / EU-Standardvertragsklauseln (SCCs) / DPA
Google Ireland Limited	Irland / USA	Authentifizierung (Google Sign-In) & Analytics	EU-US Data Privacy Framework / EU-Standardvertragsklauseln (SCCs) / DPA

Anlage 3 – Weisungsberechtigte Personen und Inkrafttreten

1. Weisungserteilung und -entgegennahme:

- **Seitens des Auftraggebers:** Befugt sind die im Kundenkonto als Administrator hinterlegten Personen. Weisungen erfolgen primär über das Dashboard oder per E-Mail von der registrierten Inhaber-E-Mail-Adresse.
- **Seitens des Auftragnehmers:** Geschäftsführung der CareTip UG (haftungsbeschränkt). Anfragen und Weisungen können gerichtet werden an: info@caretip.de.

2. Wirksamkeit und Zustandekommen:

Dieser Vertrag tritt automatisch in Kraft, sobald der Auftraggeber die Vereinbarung zur Auftragsverarbeitung im Rahmen der Online-Registrierung oder Abo-Buchung durch das Setzen des Häkchens und den Abschluss der Buchung akzeptiert hat. Eine handschriftliche Unterzeichnung ist nicht erforderlich.

Data Processing Agreement (DPA)

pursuant to Art. 28 GDPR

between

the company / business entity specified during the registration or subscription process

– hereinafter referred to as the "**Controller**" –

and

CareTip UG (haftungsbeschränkt)

Kolonnenstraße 8, 10827 Berlin, Germany

– hereinafter referred to as the "**Processor**" –

jointly referred to hereinafter as the "**Parties**".

Preamble

This Agreement sets forth the data protection obligations of the Parties in connection with the use of the CareTip platform. Pursuant to Art. 28(9) GDPR, this Agreement is concluded in electronic form (text form) upon confirmation by the Controller during the online registration or subscription ordering process.

1. Introduction, Scope, Definitions

1.1. This Agreement regulates the rights and obligations of the Parties regarding the processing of personal data on behalf of the Controller within the meaning of Art. 28 of the EU General Data Protection Regulation (GDPR).

1.2. This Agreement applies to all activities in connection with the Main Agreement (Terms of Service / Subscription Agreement for the CareTip Platform) in which the Processor, its employees, or sub-processors engaged by the Processor process personal data of the Controller.

1.3. Terms used in this Agreement shall be understood in accordance with their definitions in the GDPR. Text form (e.g., email, checkbox confirmation) is sufficient for declarations unless explicitly agreed otherwise.

2. Subject Matter and Duration of Processing

2.1. The Processor provides the CareTip software platform for digital processing, allocation, and reporting of tips and guest feedback.

2.2. The subject matter, nature, and purpose of the processing, as well as the categories of data and data subjects, are specified in this Agreement and the underlying Main Agreement.

2.3. The processing commences upon creation of the customer account and shall continue for an indefinite period until termination of the Main Agreement.

3. Nature, Purpose, and Scope of Data Processing

3.1. Purpose of Processing:

Collection, management, allocation, evaluation, and provision of digital tips, in-app notifications, payout metrics, and guest feedback for the operation of the Controller.

3.2. Categories of Personal Data:

- **Master & Contact Data:** Name, email address, phone number
- **Employee Data:** Profile data, identification IDs, payroll, and payout details.
- **Guest Data (transient/optional):** Voluntarily submitted feedback, rating scores, transaction metadata.
- **Technical Data:** IP addresses (anonymized/truncated), session logs, QR scan metadata.

(Note: Special categories of personal data pursuant to Art. 9 GDPR, such as health data, are explicitly NOT processed).

3.3. Categories of Data Subjects:

- Employees and staff of the Controller
- Customers / guests of the Controller (when using the tipping feature)

4. Obligations of the Processor

4.1. The Processor shall process personal data exclusively as contractually agreed or on documented instructions from the Controller, unless required to do so by Union or Member State law to which the Processor is subject.

4.2. The Processor warrants that persons authorized to process the personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.

4.3. Taking into account the nature of processing and the information available to the Processor, the Processor shall assist the Controller in ensuring compliance with the obligations pursuant to Articles 32 to 36 GDPR (security measures, notification of personal data breaches, data protection impact assessments).

4.4. Data processing shall generally take place within the EU/EEA. Any transfer to a third country shall only occur if the statutory requirements of Art. 44 et seq. GDPR are met (e.g., based on adequacy decisions of the EU Commission or EU Standard Contractual Clauses).

5. Technical and Organizational Measures (TOMs)

5.1. The Processor shall establish and maintain the technical and organizational measures described in **Annex 1**.

5.2. The measures may be adapted to technical developments, provided that the agreed level of security is not degraded.

5.3. Remote working / work-from-home is permitted for the Processor's employees, provided that appropriate security measures (e.g., encrypted connections, password protection, updated operating systems) are enforced.

6. Sub-processing Relationships

6.1. The Controller hereby grants the Processor general authorization to engage sub-processors. The sub-processors engaged at the time of contract execution are listed in **Annex 2**.

6.2. The Processor shall inform the Controller in advance of any intended changes concerning the addition or replacement of sub-processors (e.g., via email or in-app notification). The Controller may object to such changes within 14 days on legitimate data protection grounds. If no objection is raised within this period, the change shall be deemed approved.

6.3. Where a sub-processor undertakes processing activities in a third country, the Processor shall ensure appropriate data protection safeguards (e.g., EU-US Data Privacy Framework) are in place.

7. Rights of the Controller and Audit Rights

7.1. The Processor shall make available to the Controller on request all information necessary to demonstrate compliance with the obligations laid down in Art. 28 GDPR.

7.2. Proof of compliance may primarily be provided through current certificates, reports from independent auditors, or self-assessments.

7.3. On-site audits at the Processor's premises shall take place upon reasonable advance notice (at least 14 days) during standard business hours without disrupting operational workflows. Should on-site audits cause significant expenditure for the Processor, reasonable hourly rates may be charged to the Controller upon prior agreement, unless the audit was prompted by a substantiated suspicion of a data breach.

8. Notification Obligations in Event of Data Breaches

8.1. The Processor shall notify the Controller **without undue delay** after becoming aware of a personal data breach.

8.2. The notification shall contain the statutory minimum information regarding the nature of the breach, affected categories of data subjects, and implemented remediation measures.

9. Termination of Agreement and Data Deletion

9.1. Upon termination of the Main Agreement, the Processor shall, at the choice of the Controller, delete or return all personal data processed on behalf of the Controller, unless

statutory retention obligations (e.g., § 147 AO / § 257 HGB for tax-relevant transaction data) prevent deletion.

9.2. Following the expiration of account deletion or statutory retention periods, data shall be automatically erased or permanently anonymized.

10. Liability

Liability shall be governed by the provisions of the Main Agreement as well as statutory provisions under the GDPR (in particular Art. 82 GDPR).

Annex 1 – Technical and Organizational Measures (TOMs)

The Processor ensures an adequate level of security pursuant to Art. 32 GDPR through the following measures:

1. Confidentiality (Art. 32(1)(b) GDPR)

- **Physical Access Control:** Premises accessible only to authorized personnel; locking of office areas when absent; alarm security systems.
- **System Access Control:** Authentication via individual user accounts; multi-factor authentication (2FA) for critical systems; enforcement of complex password policies.
- **Data Access Control:** Role- and rights-management on a need-to-know basis; tenant separation at database level (isolation of customer data).
- **Separation Control:** Logical separation of test, staging, and production environments; tenant-specific data processing.

2. Integrity (Art. 32(1)(b) GDPR)

- **Transfer Control:** Encryption of all data transmissions according to current state-of-the-art standards (TLS 1.2 / TLS 1.3 with SSL certificates); encryption of data at rest with cloud infrastructure providers.
- **Input Control:** Logging of system access and administrative modifications (audit logs); traceability of data modifications.

3. Availability and Resilience (Art. 32(1)(b) GDPR)

- **Availability Control:** Utilization of high-availability cloud infrastructure with redundant server architectures; automated daily data backups.
- **Recoverability:** Regular testing procedures for backup restoration (Disaster Recovery).

4. Procedures for Regular Review (Art. 32(1)(d) GDPR)

- **Data Protection Governance:** Regular employee training and confidentiality obligations; continuous review and updating of technical security measures.

Annex 2 – Approved Sub-processors

The Controller approves the engagement of the following sub-processors upon conclusion of this Agreement:

Sub-processor / Service Provider	Location	Purpose of Processing	Legal Basis / Third Country Transfer
Stripe Payments Europe Ltd.	Ireland / USA	Payment Processing & Payouts	EU-US Data Privacy Framework / EU Standard Contractual Clauses (SCCs) / DPA
Render Services, Inc.	USA	Application Hosting & API Servers	EU-US Data Privacy Framework / EU Standard Contractual Clauses (SCCs) / DPA
Netlify, Inc.	USA	Frontend Hosting & Web Delivery	EU-US Data Privacy Framework / EU Standard Contractual Clauses (SCCs) / DPA
Plus Five Five, Inc. (Resend)	USA	System Email Delivery	EU-US Data Privacy Framework / EU Standard Contractual Clauses (SCCs) / DPA
Google Ireland Limited	Ireland / USA	Authentication (Google Sign-In) & Analytics	EU-US Data Privacy Framework / EU Standard Contractual Clauses (SCCs) / DPA

Annex 3 – Authorized Persons and Entry into Force

1. Instructions and Communications:

- **On behalf of the Controller:** Individuals designated as account administrators within the customer portal. Instructions shall primarily occur via the dashboard or from the registered owner email address.
- **On behalf of the Processor:** Management of CareTip UG (haftungsbeschränkt). Inquiries and instructions may be submitted to: info@caretip.de.

2. Validity and Execution:

This Agreement automatically enters into force once the Controller accepts the Data Processing Agreement during the online registration or subscription process by checking the designated box and completing the checkout process. Physical signatures are not required.